Profile editing at the customer edge

Report of the work done on branch feat/gateway-api, 11 October 2026

Status	Done and verified; committed with this report.
Scope	Members can edit their own profile (display name, mobile, gender, birthday, picture) and change their password in the customer SPA. Two new routes at the customer edge (`PUT /auth/me`, `POST /auth/password`), the profile screen, tests on both sides. The edge is the only module touched; the last open follow-up of the gateway-api round.
Tests	Edge: 24 tests (20 before), route tests over in-memory stores and persistence tests on the live MySQL. SPA: 74 tests in 16 files (70 before), type check and translation parity green. The edge jar driven headless against the live MySQL; checklist in section 4.

1. What it is about

The customer edge owns member identity: it registers members, logs them in, refreshes and revokes sessions, and answers the member's own row on `GET /auth/me`. Nothing wrote that row for the member, so the profile page could only print it. The member table already carries the fields a profile needs, pictures already upload through the edge's storage route for the announce gallery, and the SPA's store already had an action to replace the signed-in user. The work was the two routes, the screen and their tests.

2. Decisions

Decision	Consequence
Two routes under the member's token	`PUT /auth/me` updates display name, mobile, picture URL, gender and birthday and answers the user as GET does (400 on invalid values, 409 when another member holds the mobile). `POST /auth/password` checks the current password with BCrypt off the event loop, stores the new hash, revokes every other refresh token of the member and reissues this session's cookie, so other devices must log in again while this one carries on.
The username stays fixed	It is the login and the unique key; announces, orders and conversations refer to the member by id. The screen shows it read-only with the member id.
Mobile stays unique; blanks clear	A taken mobile answers 409 as registration does; an empty mobile and a missing birthday clear the columns (a full-row update, since the selective one skips nulls); a blank display name falls back to the username.
Picture through the storage route	The screen uploads the file as the gallery does, previews it and stores the URL on the member; the header shows it next to the name.
Validation mirrors registration	Display name up to 63, mobile up to 20 digits, plus and spaces, password at least 8 and repeated on the client, gender a three-value choice, birthday not in the future.

3. What changed

Area	Files
Edge	`gateway-api/.../auth/Account.java` (gender, birthday; old shape kept), `UserAccounts` + `R2dbcUserAccounts` (updateProfile, changePassword), `RefreshTokenStore` + `R2dbcRefreshTokenStore` (revokeAllForUser), `RefreshTokenService.replaceAll`, `AuthDtos` (ProfileUpdateRequest, PasswordChangeRequest, wider UserResponse), `AuthController` (two routes)
Edge tests	`InMemoryAuthStores` (the new operations), `EdgeRoutesTest.memberEditsProfileAndChangesPassword`, `AuthPersistenceTest` (update, password, revoke all)

Area	Files
SPA	`app/shared/model/auth.ts`, `app/shared/api/authApi.ts` (updateProfile, changePassword), `app/modules/auth/Profile.tsx` (two forms, picture upload), `app/Layout.tsx` (avatar in the header), `app/i18n/locales/{en,da,sv}/auth.json`
SPA tests	`app/modules/auth/Profile.spec.tsx` (save and store update, 409, picture, password with client checks, 401 and the fresh session)
Docs	`doc/frontend-edges.md` section 17 and 17a; this report

4. Checklist, executed 11 October 2026

Setup: the customer edge jar on 8092 and the live MySQL only; no backend and no event store needed. A member registered through the edge and logged in in a headless browser and once more over REST as a second device; a second member registered with a mobile. Both members, their tokens, the storage record and the uploaded file were deleted afterwards.

Step	Result
/me after login	username read-only with the member id, display name "Before", header "Before"
Save with the other member's mobile	alert "mobile already registered" (409), nothing saved
Picture, display name, mobile, gender, birthday, Save	upload answered a storage URL and the preview showed it; "Profile saved."; header "After Name" with the avatar image; GET /auth/me over REST answers the five fields; the avatar URL serves image/png
Wrong current password	alert "current password does not match" (401)
Password change	"Password changed. Your other devices were signed out."; the second device's refresh cookie answers 401; login with the old password 401, with the new one 200; the browser's own session survives a full reload
Console	the expected 401 of the silent refresh before login and the 409 and 401 of the two refused calls

5. Left open

- Username change, e-mail with verification, password reset by mail, account deletion.
- The payouts card below the profile needs the order module running; without it the card shows its loading state (seen in the run, where no backend was started).